Lab 22 — Identity & Access Management with PAM and sudo

You will model RBAC with Linux groups, scope `sudo` per role, and enforce time-of-day restrictions through PAM.

Run on https://killercoda.com/playgrounds/scenario/ubuntu

Required software (free): - `sudo`, `pam` (pre-installed)

Step 1 — Create three roles (groups)

```
groupadd webops
groupadd dbops
groupadd auditor
useradd -m -G webops  alice
useradd -m -G dbops   bob
```

```
useradd -m -G auditor carol
for u in alice bob carol; do echo "$u:Lab1234!" | chpasswd; done
```

Step 2 — Scope sudo by role (RBAC)

```
cat > /etc/sudoers.d/roles <<'EOF'
%webops  ALL=(ALL) NOPASSWD: /bin/systemctl restart nginx, /bin/systemctl status nginx
%dbops   ALL=(ALL) NOPASSWD: /usr/bin/mysqldump, /bin/systemctl restart mariadb
%auditor ALL=(ALL) NOPASSWD: /usr/bin/cat /var/log/auth.log, /usr/bin/journalctl
EOF
chmod 440 /etc/sudoers.d/roles
```

```
visudo -cf /etc/sudoers.d/roles
```

Step 3 — Verify least privilege

```
su - alice -c 'sudo systemctl status nginx 2>&1 | head -2'
su - alice -c 'sudo mysqldump --help 2>&1 | head -1'   # should DENY
su - carol -c 'sudo cat /var/log/auth.log | tail -2'
```

Alice can restart nginx but not run mysqldump. RBAC is enforced.

Step 4 — Time-of-day restriction with PAM (`pam_time`)

```
cat >> /etc/security/time.conf <<'EOF'
# Allow alice to log in only Mon-Fri 09:00-18:00 SGT
*;*;alice;Wd0900-1800
EOF
```

```
grep -q pam_time /etc/pam.d/login || \
   echo 'account required pam_time.so' >> /etc/pam.d/login
```

The format is `services;ttys;users;times`. `Wd` = weekdays.

Step 5 — Lockout policy with `pam_faillock`

```
cat > /etc/security/faillock.conf <<'EOF'
deny = 5
unlock_time = 600
fail_interval = 900
EOF
```

```
# enable in PAM (common-auth's pam_unix line is "[success=1 default=ignore]" on modern Ubuntu)
sed -i '/pam_unix.so/i auth required pam_faillock.so preauth silent' /etc/pam.d/common-auth
sed -i '/pam_unix.so/a auth [default=die] pam_faillock.so authfail' /etc/pam.d/common-auth
faillock --user alice
for i in 1 2 3 4 5 6; do su - alice -c 'true' < /dev/null 2>/dev/null; done
faillock --user alice
```

Step 6 — Demonstrate de-provisioning (offboarding)

```
usermod -L alice          # lock account
chage -E 0 alice          # expire it
```

```
passwd -S alice
```

Free online tools

- **NIST SP 800-162 ABAC guide** — https://csrc.nist.gov/publications/detail/sp/800-162/final
- **Keycloak (free IdP)** — https://www.keycloak.org
- **FreeIPA** — https://www.freeipa.org
- **JumpCloud (free up to 10 users)** — https://jumpcloud.com
- **SSO.dev SAML/OIDC tester** — https://sso.dev

What you learned

- How groups + sudoers map directly to RBAC.
- That PAM stacks compose: time, faillock, and unix auth in one chain.
- The four offboarding steps every IAM playbook needs.